Support Desk Backend: E1–E3 Alignment Report

Branch `feature/E3-sla-queue` · 2 November 2026 · Spring Boot 3.4.1, Java 21, PostgreSQL 16 · Prepared for Youssef Waleed and the team

This report lists every requirement of epics **E1 (access, roles and audit)**, **E2 (caller verification and Customer 360)** and **E3 (tickets, queue and SLA)**, what the code did before this round of work, what was missing, and what was built. It also records the earlier E1 work merged through pull requests #1–#8, so the whole story is in one place.

153	25	51	3
automated tests, all passing	API operations documented in Swagger	Postman requests, all passing live	new migrations (V7–V9) + 1 demo seed

> **Status of the code:** nothing in this round is committed yet. The changes sit on `feature/E3-sla-queue` next to the team's own uncommitted E3 SLA-queue work. Section 9 lists what to check before committing.

1. How to run and try it

- Start the database: `docker compose up -d` (Postgres on `localhost:5434`), then run `SupportDeskApplication`.
- Swagger UI: `http://localhost:8080/swagger-ui.html` (OpenAPI JSON: `/v3/api-docs`). Press **Authorize** and paste the `accessToken` from login.
- Postman: import `postman/SupportDesk.postman_collection.json` and run it top to bottom with the Collection Runner (7 folders).
- Seeded staff (local profile only): `mona` AGENT, `youssef` GUIDE_ADMIN, `nour` REVIEWER, password `Password123!`.
- Seeded customers: Sara `CIF-100245` (3 failed logins with ERR_AUTH_503 in the last hours), Mai `CIF-100311` (not enrolled), Ahmed `CIF-100101` (no failures). The activity seed re-runs on every start, so "the last 6 hours" always has data.

2. Earlier E1 work (already merged, PRs #1–#8)

Area	What was done
Logout (PR #1–#3)	Logout ends the session everywhere: a per-user `token_version` makes old access tokens fail, and the refresh token row is deleted. `/refresh` answers 401 (not 500) for an unknown or expired refresh token.
Errors (PR #3)	One `ErrorCode` enum holds every code, HTTP status and message; every error body is `{code, message, fieldErrors, path, timestamp}`. Database constraint conflicts answer 409.
Staff seeding (PR #3)	Registration removed (internal system). Staff accounts come from a local-only Flyway seed (`db/seed/R__seed_staff_users.sql`), never in production.
Permissions (E1-S2, PR #5)	One permission matrix (`Permissions`) drives `SecurityConfig`: no token 401, wrong role 403. `/api/auth/me` returns `allowedScreens`. `PermissionMatrixTest` pins every role × area (38 tests).
403 audit (PR #5)	Every 403 writes `ACCESS_DENIED`. Fix: the audited IP is the real connection, never the forgeable `X-Forwarded-For` header.
API docs (PR #6)	springdoc 2.8.0, Swagger UI with JWT Authorize, Postman collection in the repo.

3. E1: Access, roles and audit

Requirement	Was	Now	What changed / where
S1 Land on the role's home	Partial	Partial	`/me` gives screens per role. Admin landing on "Review queue" conflicts with the current matrix (Admin has no review access): team decision.
S1 5 failures in 15 min lock for 15 min	Partial	Done	Failures now count only inside a 15-minute window (`first_failed_login_at`, V8). `LoginAttemptServiceTest`.
S1 USER_LOCKED audited	Missing	Done	Written with the lock, including `lockedUntil`.
S1 30 min inactivity → sign in again	Missing	Done*	Refresh token lasts 30 min and every refresh pushes it out (sliding). *Idle time is measured at refresh, so up to 15 min off. Keeping unsaved form text is frontend.
S1 USER_LOGIN audited with role and IP	Missing	Done	Written in `AuthService.login`.
S2 Agent → admin API 403 + ACCESS_DENIED	Done	Done	Now also records the role.
S2 Admin → customer/ticket API 403	Done	Done	URL rules + `@PreAuthorize` on controllers.
S2 "Not available for your role" page	Frontend	Frontend	Backend supplies `allowedScreens`.
S2 Test covers every matrix row	Done	Done	`PermissionMatrixTest`.
S3 Record has user, role, action, entity, entity ID, time, before, after	Partial	Done	V7 adds role, entity, entity_id, before_state, after_state (JSON).
S3 Written in the same transaction	Missing	Done	`AuditService` uses `Propagation.MANDATORY`: an audit row can only join the business transaction. A test proves writing one alone is refused.
S3 No update/delete; INSERT+SELECT only	Partial	Mostly	`AuditLog` is `@Immutable`; a database trigger blocks UPDATE, DELETE and TRUNCATE. A separate INSERT/SELECT-only DB user is an ops/team decision.
S3 Audit log screen: filters + paging	Missing	Done	`GET /api/audit/logs` (Admin, Reviewer): user, action, entity, entityId, from, to; page/size/sort.
S3 Index on (entity, entity_id, created_at)	Missing	Done	V7.
S4 CUSTOMER_DATA_VIEWED	Missing	Done	Written when a verified agent opens Customer 360.
S4 CUSTOMER_SEARCHED without raw text	Missing	Done	Stores only what matched (CIF, NATIONAL_ID...) and the result count. A test checks the national ID never appears.
S4 >30 searches in 10 min → 429	Missing	Done*	`SearchRateLimiter`, per agent. *In memory, one app instance only.
S4 Team Leader notified	Missing	Blocked	No Team Leader role or notifications yet (E10). Logged as a warning for now.
Tech: JWT 15 min	5 min	Done	`session-timeout: 15m`.
Tech: role and permission tables	Enum	Enum	Roles stay an enum; tables are a team decision.

4. E2: Caller verification and Customer 360

Requirement	Was	Now	What changed / where
S1 One search: CIF, national ID, mobile, ticket	Missing	Done	`GET /api/customers/search?q=`. Mobile accepts 01..., 20... or +20...; tickets #2001 or 2001 return the owner. Rows: name, segment, masked mobile, enrollment, open-ticket count.
S1 ADO number search	Missing	Blocked	Tickets have no Azure DevOps number until E5.
S1 "No match" message	Missing	Done	"No match. Check the digits and the ID type."
S1 "/" focuses search	Frontend	Frontend	—
S2 Nothing shows before verification	Missing	Done	Every Customer 360 endpoint answers 403 `CALLER_NOT_VERIFIED` without a verification for this agent.
S2 Fewer than 2 checks blocked	Done	Done	Message now "Two checks must pass."
S2 CALLER_VERIFIED + "verified HH:MM"	Partial	Done	Audited with the checks; header returns `verifiedAt`.
S2 Caller failed → audited, no data	Missing	Done	`POST /{cif}/verification-failed` writes CALLER_VERIFICATION_FAILED.
S2 End verification locks again	Done	Done	`POST /{cif}/end-call`.
S3 National ID last 4; mobile first 3 + last 4	Partial	Done	Server-side `Masking`. Was last 4 of mobile only, no national ID.
S3 Reveal one field, audited by name	Missing	Done	`POST /{cif}/reveal` (NATIONAL_ID or MOBILE); CUSTOMER_FIELD_REVEALED stores the field, never the value.
S3 Re-mask on leave	Frontend	Frontend	Values are only ever returned by the reveal call.
S4 Diagnosis: count, type, time range, code, service	Missing	Done	`GET /{cif}/diagnosis`: most frequent failure of the last 6 hours (ties go to the most recent) and a plain sentence.
S4 No failures → device/network hint	Missing	Done	"No failures in the last 6 hours. Check the customer's device or network."
S4 Other services listed to rule out	Missing	Done	`servicesWithoutFailures`, from the top-level ticket categories.
S4 Matching incident; "Run guide"	Missing	Blocked	Needs E6 incidents and E4 guides.
S5 Activity: default 6h + failures; Today, 7 days, Custom; platform/service chips; empty state	Missing	Done	`GET /{cif}/activity`, new `customer_activity_log` table (V9) with index (customer, time). Counts are taken before the chips so each chip shows its number. "Today" is the bank's day (Africa/Cairo).
S6 Tickets: origin, status; repeat caller	Missing	Done	`GET /{cif}/tickets`; "Repeat caller" when more than one ticket in 20 days.
S6 ADO number; Incidents & RCA tab	Missing	Blocked	Needs E5/E6.

5. E3: Tickets, queue and SLA

Requirement	Was	Now	What changed / where
S1 Required fields incl. priority	Partial	Done	Priority is now required (was optional).
S1 TRX- reference for Transfers/Payments	Done	Done	—
S1 Latest failed error code attached	Missing	Done	From the customer's latest failure on the ticket's service; falls back to the category default.
S1 Duplicate open ticket warning	Done	Done	Precheck + 409.
S1 Link to an open incident	Missing	Blocked	Needs E6.
S2 Fixed state machine; reopen	Done	Done	—
S2 TICKET_TRANSITION_REJECTED audited	Missing	Done	Events were published but never recorded. Written in its own transaction so it survives the 422 rollback.
S2 TICKET_STATUS_CHANGED with before/after	Missing	Done	`TicketAuditListener`; also TICKET_CREATED.
S3 Targets 2h / 8h / 24h / 72h	Done	Done	—
S3 One value + meter	Partial	Done	`slaLabel`: "1h 30m left", "Paused", "Met" or "Breached 1h 15m"; `slaPercentUsed` for the meter.
S3 Amber at 75%, SLA_WARNING/SLA_BREACHED once	80%	Done	Warning moved to 75%; both crossings are now audited (the scheduler already fired them once).
S3 Pause on "Waiting on customer"; runs through "SRE fixed"	Done	Done	—
S4 Risk order: confirm near top, paused at bottom	Partial	Done	"SRE fixed" first, paused last, otherwise highest % used. (Earlier order mixed paused tickets in.)
S4 Row: ID, issue, customer, segment, platform, error code, SLA, origin, action	Partial	Done	Added segment, platform, error code, origin, SLA label, next action.
S4 Chips All / At risk / Confirm fix / Auto-created	Other chips	Done	Were ALL, AT_RISK, BREACHED, PAUSED. AT_RISK now includes breached.
S4 Hide tickets waiting for triage	Missing	Blocked	No triage status yet (E9).
S5 Exactly one pinned next step	Missing	Done	`NextAction`, shared by queue rows and the ticket: Start guide, Escalate, Resume, Wait for SRE, Ask SRE for update, Call & confirm, Close.
S5 Timeline, Customer contact, Audit tabs with counts	Missing	Done	Timeline and Audit read the append-only audit trail; contacts have their own table (V9).
S5 Work tab (guide runs, SRE panel, same-incident tickets)	Missing	Blocked	Needs E4–E6.
S6 Log what the customer was told + CUSTOMER_CONTACTED	Missing	Done	`POST /api/tickets/{n}/contacts`. Guide scripts logged automatically: E4.
S7 List: All / Open / Resolved & closed; search; 8 per page	Missing	Done	`GET /api/tickets`: the agent's own tickets, search by #number or CIF (ADO: E5).
Screens (Home, list, workspace)	Frontend	Frontend	—

6. API reference (all in Swagger)

Method	Path	Who	Purpose
POST	`/api/auth/login`	Public	Access + refresh token; audits USER_LOGIN / USER_LOCKED
POST	`/api/auth/refresh`	Public	New access token; pushes the 30-min idle limit out
POST	`/api/auth/logout`	Logged in	Ends every session of the user
GET	`/api/auth/me`	Logged in	User and allowed screens
GET	`/api/audit/logs`	Admin, Reviewer	Audit search with filters and paging
GET	`/api/customers/search`	Agent	Search (rate limited)
GET	`/api/customers/{cif}`	Agent, verified	Customer 360 header, masked
POST	`/api/customers/{cif}/verify`	Agent	Verify the caller (2+ checks)
POST	`/api/customers/{cif}/verification-failed`	Agent	Caller failed
GET	`/api/customers/{cif}/verification`	Agent	Verification status
POST	`/api/customers/{cif}/end-call`	Agent	End verification
POST	`/api/customers/{cif}/reveal`	Agent, verified	Reveal one field
GET	`/api/customers/{cif}/diagnosis`	Agent, verified	What the logs already say
GET	`/api/customers/{cif}/activity`	Agent, verified	Activity timeline
GET	`/api/customers/{cif}/tickets`	Agent, verified	Customer's tickets
GET	`/api/tickets`	Agent	My ticket list, paged by 8
POST	`/api/tickets`	Agent	Create a ticket (verified customer)
POST	`/api/tickets/precheck`	Agent	Duplicate warning before create
GET	`/api/tickets/queue`	Agent	Home queue with chip counts
GET	`/api/tickets/{number}`	Agent	Ticket with SLA label and next step
PATCH	`/api/tickets/{number}/status`	Agent	Change status
POST / GET	`/api/tickets/{number}/contacts`	Agent	Log / list customer contact
GET	`/api/tickets/{number}/timeline`	Agent	Timeline tab
GET	`/api/tickets/{number}/audit`	Agent	Audit tab

7. Database and audit changes

Migration	Content
`V7__audit_log_append_only`	Role, entity, entity_id, before/after columns; index (entity, entity_id, created_at); triggers that block UPDATE, DELETE and TRUNCATE.
`V8__add_failed_login_window`	`users.first_failed_login_at` for the 15-minute failure window.
`V9__customer_360_and_ticket_contacts`	`customers.enrollment_status`, `customer_activity_log` (+ index), `ticket_contacts`, wider audit action check.

`R__seed_customer_activity` (local only)	Demo activity relative to now; re-runs on every start.

Audit actions now written: ACCESS_DENIED, USER_LOGIN, USER_LOCKED, CUSTOMER_SEARCHED, CALLER_VERIFIED, CALLER_VERIFICATION_FAILED, CUSTOMER_DATA_VIEWED, CUSTOMER_FIELD_REVEALED, TICKET_CREATED, TICKET_STATUS_CHANGED, TICKET_TRANSITION_REJECTED, CUSTOMER_CONTACTED, SLA_WARNING, SLA_BREACHED.

8. Tests added or changed

- **AuditTrailIntegrationTest** (8): login/lock audits, sliding refresh, customer view, trigger, MANDATORY transaction, search API, roles.
- **Customer360IntegrationTest** (12): search types and masking, no match, audit without text, 429, gate, caller failed, reveal, diagnosis, activity, tickets.
- **TicketWorkflowIntegrationTest** (5): auto error code, required priority, status audits incl. rejected, tabs, list paging.
- **LoginAttemptServiceTest** (3), **CustomerRulesTest** (6), **TicketRulesTest** (10): window, masking, parsing, rate limit, next step, SLA label.
- Updated to the stories: queue order and chips (`TicketQueryServiceTest`, `TicketControllerTest`), "Two checks must pass.", constructor changes, Mohab's audit test no longer empties the append-only table.

9. Before committing: decisions and risks

- **Two pieces of work on one branch.** This E1–E3 alignment is mixed with the team's uncommitted E3 SLA-queue work. Consider separate commits.
- **Breaking changes for the frontend:** `GET /api/customers/{cif}` now needs a verified caller and returns a different, masked body; ticket `priority` is required; queue chips are ALL / AT_RISK / CONFIRM_FIX / AUTO_CREATED.
- **Migration numbers.** V6 notes that "Member 3" planned notes/timeline as V7. V7–V9 are used here; agree numbering before merging another branch.
- **Teammates' tests were changed** where they contradicted the stories (queue order with paused tickets, the verification message).
- **Integration tests use the local dev database** and leave small test users and tickets behind, since audit rows can never be deleted.
- **Open team decisions:** Admin landing page, INSERT/SELECT-only DB user, role tables, Team Leader role and alerts.
- **Blocked by later epics:** incidents (E6), guides (E4), Azure DevOps numbers and SRE panel (E5), triage (E9), notifications (E10).

Generated from the code on the branch on 2 November 2026. "Done" rows were checked by the automated tests, the live Postman run against PostgreSQL, or both. The SLA_WARNING / SLA_BREACHED audit rows have no dedicated test yet: the scheduler's crossings are tested, the audit write is not.